

Weekend Recon: Node Base Image

Scan Overview

A Trivy vulnerability scan was completed against the node:18-alpine container image on 10 August 2026. The scanned image used Alpine Linux 3.21.3 and image digest sha256:8d6421d663b4c28fd3ebc498332f249011d118945588d0a35cb9bc4b8ca09d9e.

The scan produced the following baseline:

- Alpine packages: 50 vulnerabilities: 19 Low, 14 Medium, 15 High and 2 Critical.
- Node.js packages: 27 vulnerabilities: 2 Low, 7 Medium, 17 High and 1 Critical.
- The two critical Alpine entries relate to the same OpenSSL vulnerability found in both libcrypto3 and libssl3.

Top Two Vulnerabilities

1. CVE-2026-59873: node-tar Decompression Denial of Service

Trivy identified CVE-2026-59873 in the Node.js tar package version 6.2.1. The patched version identified by the scan is 7.5.19.

The vulnerable package does not adequately limit the amount of data, number of files or decompression ratio when processing compressed tar archives. An attacker could provide a small, specially constructed gzip archive that expands into a very large amount of data. If the application or its build process extracts the archive, it could consume the server's disk space and CPU resources, causing the Medusa backend to slow down or become unavailable.

Exploitation requires the application, deployment pipeline or package installation process to extract an attacker-controlled archive. The recommended mitigation is to use a supported Node.js base image containing a patched version of node-tar, restrict untrusted archive processing and apply CPU, memory and storage limits to the container.

Reference: [GitHub Security Advisory for CVE-2026-59873](#)

2. CVE-2026-31789: OpenSSL Heap Buffer Overflow

Trivy identified CVE-2026-31789 in OpenSSL packages libcrypto3 and libssl3 version 3.3.3-r0. The patched Alpine package version is 3.3.7-r0.

An attacker could create an unusually large and malicious X.509 certificate. If a vulnerable 32-bit application processes and converts specific certificate fields into hexadecimal format, an integer calculation can allocate an undersized memory buffer. This may cause a crash or, in severe circumstances, allow attacker-controlled code execution.

This vulnerability specifically affects 32-bit platforms. The scanned image was pulled on a 64-bit Intel environment, so the direct exploitation path is unlikely to apply to this deployment. However, the outdated OpenSSL packages should still be replaced and the rebuilt image rescanned before deployment.

Reference: [NVD entry for CVE-2026-31789](#)

Deployment Recommendation

The current node:18-alpine image should not be approved for production deployment. Node.js 18 is end-of-life and no longer receives normal security updates. In addition, current Medusa documentation requires Node.js 20 or later.

The application should be rebuilt and tested on a supported image such as node:24-alpine or node:22-alpine, followed by another Trivy scan. Deployment should proceed only after critical findings have been removed or formally assessed and accepted.

References: [Node.js release status](#) and [Medusa Docker requirements](#)

AI Prompt Journal

- **Prompt Used:** "I am preparing to deploy an e-commerce backend on the node:18-alpine Docker image. Analyze these Trivy scan results. Identify the top 2 vulnerabilities (CVEs) I need to be aware of, and explain in simple terms how an attacker might exploit them."
- **AI Response:** The AI prioritized CVE-2026-59873, a critical node-tar decompression denial-of-service vulnerability, and CVE-2026-31789, a critical OpenSSL heap buffer overflow. It explained the required attack conditions, affected components, practical impact and available patched versions. It also noted that the OpenSSL vulnerability is limited to 32-bit platforms.
- **My Verification:** The official Docker Library node:18-alpine image was successfully pulled through Amazon ECR Public after the local network repeatedly reset connections to Docker Hub. The image was tagged locally as node:18-alpine, and its digest was confirmed as sha256:8d6421d663b4c28fd3ebc498332f249011d118945588d0a35cb9bc4b8ca09d9e. The scan was completed using the official Trivy container and vulnerability database hosted on Amazon ECR Public. The baseline findings and the two distinct critical CVEs were successfully identified.